

La raccolta illecita di dati tramite *form* online

Profili giuridici e tecnici della raccolta di dati personali
mediante moduli web inadeguatamente predisposti

Martino Papa Alessio Minati

Università degli Studi di Firenze
Corso di Informatica Forense

Anno Accademico 2025/2026

- **Reg. (UE) 2016/679** – GDPR
- **D.Lgs. 196/2003** – Codice Privacy
- **D.Lgs. 101/2018** – Adeguamento al GDPR

Art. 4, n. 1 GDPR – Definizione di dato personale

“**dato personale**”: qualsiasi informazione riguardante una persona fisica identificata o identificabile.

Art. 9 GDPR – Trattamento di categorie particolari di dati personali

Par. 1: “È vietato trattare dati personali che rivelino l’origine razziale o etnica, le opinioni politiche, le convinzioni religiose o filosofiche, o l’appartenenza sindacale, nonché trattare dati genetici, dati biometrici intesi ad identificare in modo univoco una persona fisica, dati relativi alla salute o alla vita sessuale o all’orientamento sessuale della persona.”

Par. 2: Il divieto non si applica nei casi ivi tassativamente previsti, tra cui il *consenso esplicito* dell’interessato (lett. a).

Art. 5 GDPR – Principi applicabili al trattamento dei dati personali

- a) **Liceità, correttezza e trasparenza**
- b) **Limitazione della finalità**
- c) **Minimizzazione dei dati**
- d) **Esattezza**
- e) **Limitazione della conservazione**
- f) **Integrità e riservatezza**

Art. 13 GDPR – Obbligo di informativa al momento della raccolta dati

Art. 7 GDPR – Il consenso deve essere:

1. Libero
2. Specifico
3. Informato
4. Inequivocabile

Principio: presunzione di responsabilità

L'art. 82 GDPR sancisce il diritto di ogni interessato che abbia subito un danno — materiale o immateriale — in conseguenza di una violazione del Regolamento, di ottenere il **risarcimento** dal titolare o dal responsabile del trattamento.

Onere della prova invertito

Il titolare è esonerato da responsabilità **soltanto se dimostra** che l'evento dannoso non gli è in alcun modo imputabile.

⇒ *Si tratta di una presunzione di responsabilità con onere della prova a carico del titolare.*

Sanzione ordinaria (par. 4)

fino a 10 milioni €

oppure

2% del fatturato mondiale

(es. violazione del consenso, mancata informativa)

Sanzione aggravata (par. 5)

fino a 20 milioni €

oppure

4% del fatturato mondiale

(es. violazione dei principi base, trattamento di dati particolari senza base giuridica)

Art. 167 D.Lgs. 196/2003

“1. Salvo che il fatto costituisca più grave reato, chiunque, al fine di trarne per sé o per altri profitto ovvero al fine di recare ad altri un danno, procede al trattamento di dati personali in violazione di quanto disposto [...] è punito, se dal fatto deriva nocumento, con la **reclusione da sei mesi a un anno e sei mesi**.

2. Se il fatto di cui al comma 1 riguarda dati genetici, biometrici o relativi alla salute, alla vita sessuale, all'orientamento sessuale o alle opinioni, [...] la pena è la **reclusione da uno a tre anni**.”

Il danno e il profitto possono essere anche di natura non economica

Art. 167-bis D.Lgs. 196/2003

“1. Salvo che il fatto costituisca più grave reato, chiunque comunica o diffonde, al fine di trarne profitto per sé o altri ovvero al fine di arrecare danno, un archivio automatizzato o una parte sostanziale di esso contenente dati personali oggetto di trattamento su larga scala, in violazione degli articoli 2-ter, 2-sexies e 2-octies, è punito con la **reclusione da uno a sei anni**.”

Si applica in caso di **data breach deliberato**: cessione o pubblicazione non autorizzata di dati raccolti tramite *form*

Art. 167-ter D.Lgs. 196/2003

“1. Salvo che il fatto costituisca più grave reato, chiunque, al fine di trarne profitto per sé o altri ovvero di arrecare danno, acquisisca con mezzi fraudolenti un archivio automatizzato o una parte sostanziale di esso contenente dati personali oggetto di trattamento su larga scala è punito con la **reclusione da uno a quattro anni.**”

Riguarda in particolare i *form* ingannevoli (**dark patterns**) i quali inducono l'utente a fornire dati senza esserne **pienamente consapevole**

Un ente pubblico aveva predisposto sul proprio sito web un modulo di contatto (*form*) che raccoglieva nome, cognome, indirizzo e-mail e numero di telefono degli utenti, senza che nella pagina fosse presente alcuna informativa adeguata ai sensi dell'art. 13 GDPR. Il Garante ha accertato la violazione dei principi di liceità, correttezza e trasparenza (art. 5, par. 1, lett. a GDPR) e ha irrogato una sanzione pecuniaria amministrativa, disponendo altresì la rettifica del *form*.

La Suprema Corte ha confermato la configurabilità del reato di cui all'art. 167 del Codice Privacy in capo a un operatore che aveva sistematicamente raccolto, tramite un servizio web, dati personali degli utenti senza il loro consenso e li aveva successivamente ceduti a terzi a fini commerciali. La Corte ha precisato che il *fine di profitto* richiesto dalla norma è integrato anche dalla sola prospettiva di un vantaggio economico indiretto, e che il *nocumento* può consistere anche in un danno non patrimoniale, quale la perdita del controllo sui propri dati personali.

Grazie per l'attenzione

Martino Papa | Alessio Minati

Università degli Studi di Firenze

Corso di Informatica Forense – A.A. 2025/2026

*La raccolta illecita di dati tramite form online:
profili giuridici e tecnici*